DJANGO 6.0.6 × APPLE LIQUID GLASS × THAI RBAC SYSTEM

ระบบยืนยันตัวตนและการจัดการสิทธิ์ผู้ใช้งาน

(User Authentication & RBAC Architecture)

คู่มือสรุปสถาปัตยกรรมระบบ · ER Diagram · System Flowcharts · Step-by-Step Tutorial · RBAC Matrix

[โครงการ]	ระบบร้านค้าออนไลน์ THAMMATHAD SHOP	**[สาขาวิชา]**	วิทยาการคอมพิวเตอร์ มหาวิทยาลัยราชภัฏกำแพงเพชร
[ผู้พัฒนา]	นายธรรมธัช รูปไธสง	**[ผลทดสอบ]**	117 Tests Passed (ผ่าน 100% ครบทุกโมดูล)

Register & Validation | Login / Logout + Session | Profile & GIF Cover | Protected Pages & 403 | RBAC Roles & Matrix

สถาปัตยกรรมระดับโปรดักชัน · Dual-Zone Architecture · PythonAnywhere Staging · SQLite

ส่วนที่ 1

สรุปภาพรวมสถาปัตยกรรมระบบ (Architecture Overview)

ระบบออกแบบบน Dual-Zone Architecture แยกขอบเขต Public Shop และ Staff Zone อย่างเด็ดขาด พร้อมระบบความปลอดภัยระดับมาตรฐาน

1. Register & Validation

- CustomerRegistrationForm (forms.py)
- ตรวจเบอร์โทรไทย 10 หลัก (08/09/06...)
- ตรวจอีเมลซ้ำในระบบ + รหัสผ่าน >= 6 ตัว
- Real-time Password Strength Meter
- ผูกเข้า Django Group 'Member' อัตโนมัติ

2. Login / Logout & Session

- แยก StaffLoginView (/staff/login/) ชัดเจน
- CustomerLoginView (/account/login/)
- Remember Me ติ๊กจำ 14 วัน (1,209,600 วิ)
- ปิดเบราว์เซอร์ล้างเซสชันทันที (set_expiry 0)
- Logout เป็น POST-only ป้องกัน CSRF 100%

3. Profile & GIF Cover

- รองรับรูป Avatar และ Cover รูปแบบ GIF ขยับได้
- สรุปยอดคำสั่งซื้อและยอดสะสม Real-time
- วันที่สมัครแสดงปฏิทินไทย พ.ศ. (ThaiCalendar)
- CustomerPasswordChangeView เปลี่ยนรหัสปลอดภัย
- รองรับสมุดที่อยู่ลูกค้าหลายที่อยู่ (1:N)

4. Protected Pages & 403 Forbidden Access Control

- ป้องกันหน้าสำคัญด้วย ManagerRequiredMixin และ StaffRequiredMixin
- หากยังไม่ล็อกอิน: 302 Redirect ไปหน้า Staff Login พร้อม next parameter
- หากล็อกอินแล้วแต่ไม่มีสิทธิ์: raise PermissionDenied() ส่งรหัส HTTP 403
- หน้า 403.html ดีไซน์ Apple Liquid Glass พร้อมปุ่ม 'สลับบัญชี' 1 คลิก

5. RBAC — Role-Based Access Control & Groups

- แบ่ง 3 บทบาทชัดเจน: Manager (ผู้จัดการ), Staff (เจ้าหน้าที่), Member (สมาชิก)
- RBAC Portal (/staff/users/): ค้นหา, กรองสถานะ, สลับบทบาทได้ทันที
- ซิงค์สถานะ is_staff อัตโนมัติเมื่อตั้งเป็น Manager หรือ Staff
- ระบบทำงานร่วมกับ Django Groups & Permissions ตามหลัก OOP & Service Layer

Dual-Zone Architecture — ขอบเขตสิทธิ์การใช้งาน:

[Public Shop] (ไม่ต้องล็อกอิน): / (หน้าแรก), /shop/ (สินค้า), ตะกร้าสินค้า, สมัครสมาชิก, เข้าสู่ระบบลูกค้า, ติดตามสถานะออเดอร์

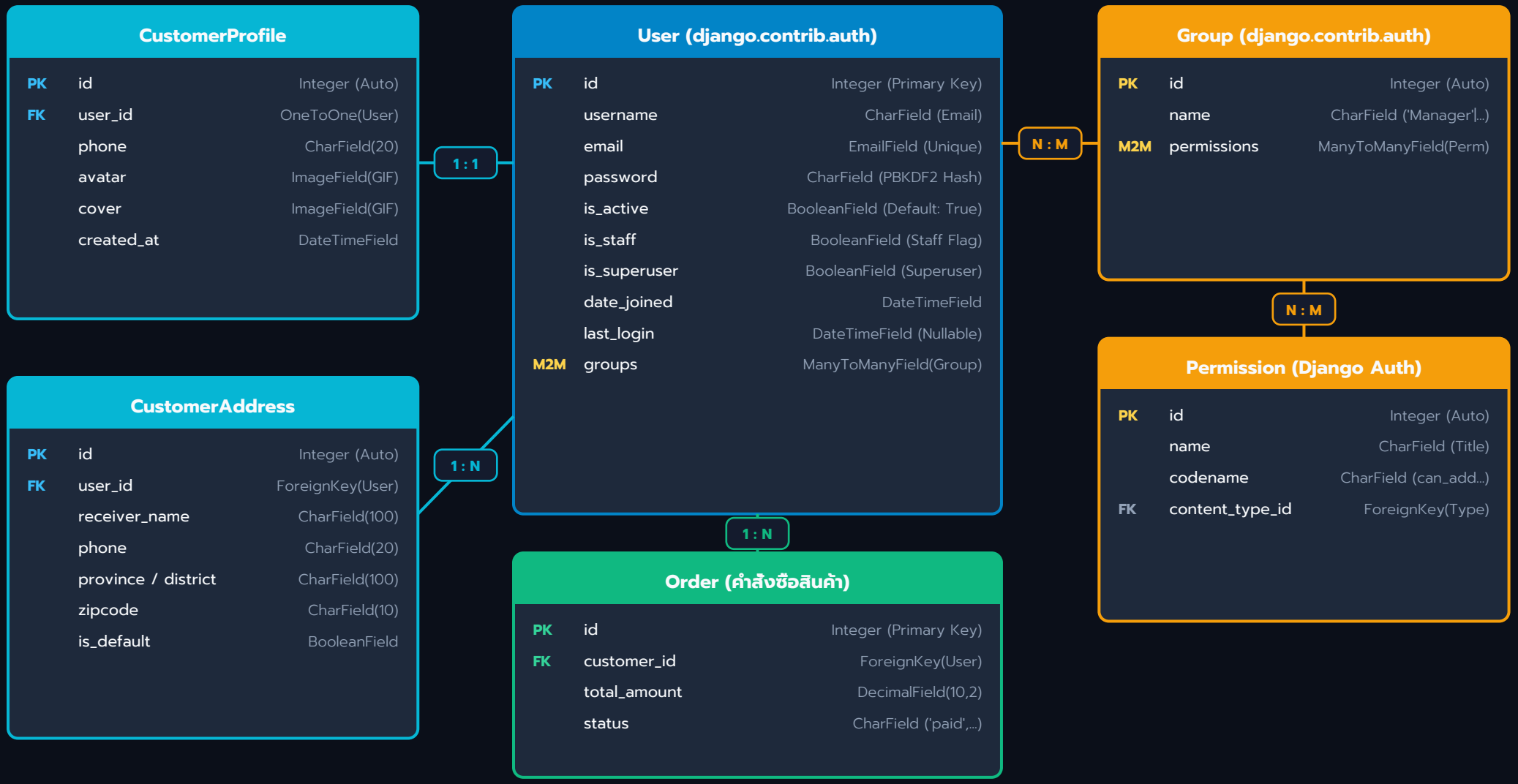
[Staff Protected Zone] (ต้องมีสิทธิ์ Staff/Manager): /employees/ (พนักงาน), /orders/ (ออเดอร์), /product/manage/ (คลัง), /staff/users/ (RBAC Portal เฉพาะ Manager)

นายธรรมธัช รูปไธสง · มรภ.กำแพงเพชร

ส่วนที่ 2

โครงสร้างฐานข้อมูลความสัมพันธ์ผู้ใช้งาน (User Model ER Diagram)

ความสัมพันธ์: User <-> CustomerProfile (1:1) · User <-> CustomerAddress (1:N) · User <-> Group (N:M) · User <-> Order (1:N)



ส่วนที่ 3

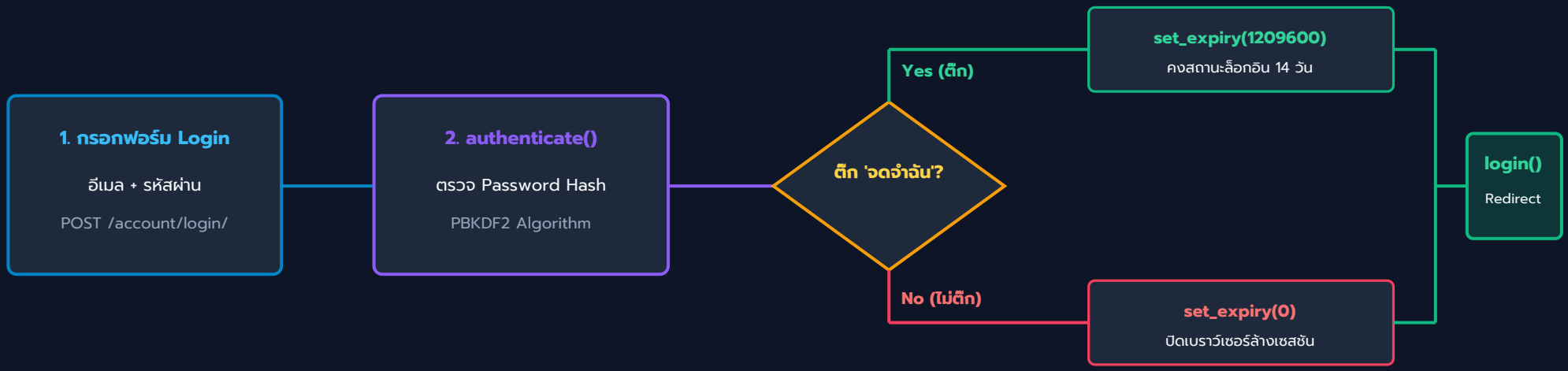
แผนผังการทำงานของระบบ (System Flowcharts — Part 1)

1. ลำดับขั้นตอนการสมัครสมาชิก (Registration Lifecycle)



[หมายเหตุ] กรณีข้อมูลไม่ถูกต้อง (Form Invalid): แสดงข้อความแจ้งเตือนใต้ช่องกรอกทันที + ไม่บันทึกลงฐานข้อมูล

2. การเข้าสู่ระบบ & ควบคุมอายุ Session (Login & Remember Me)

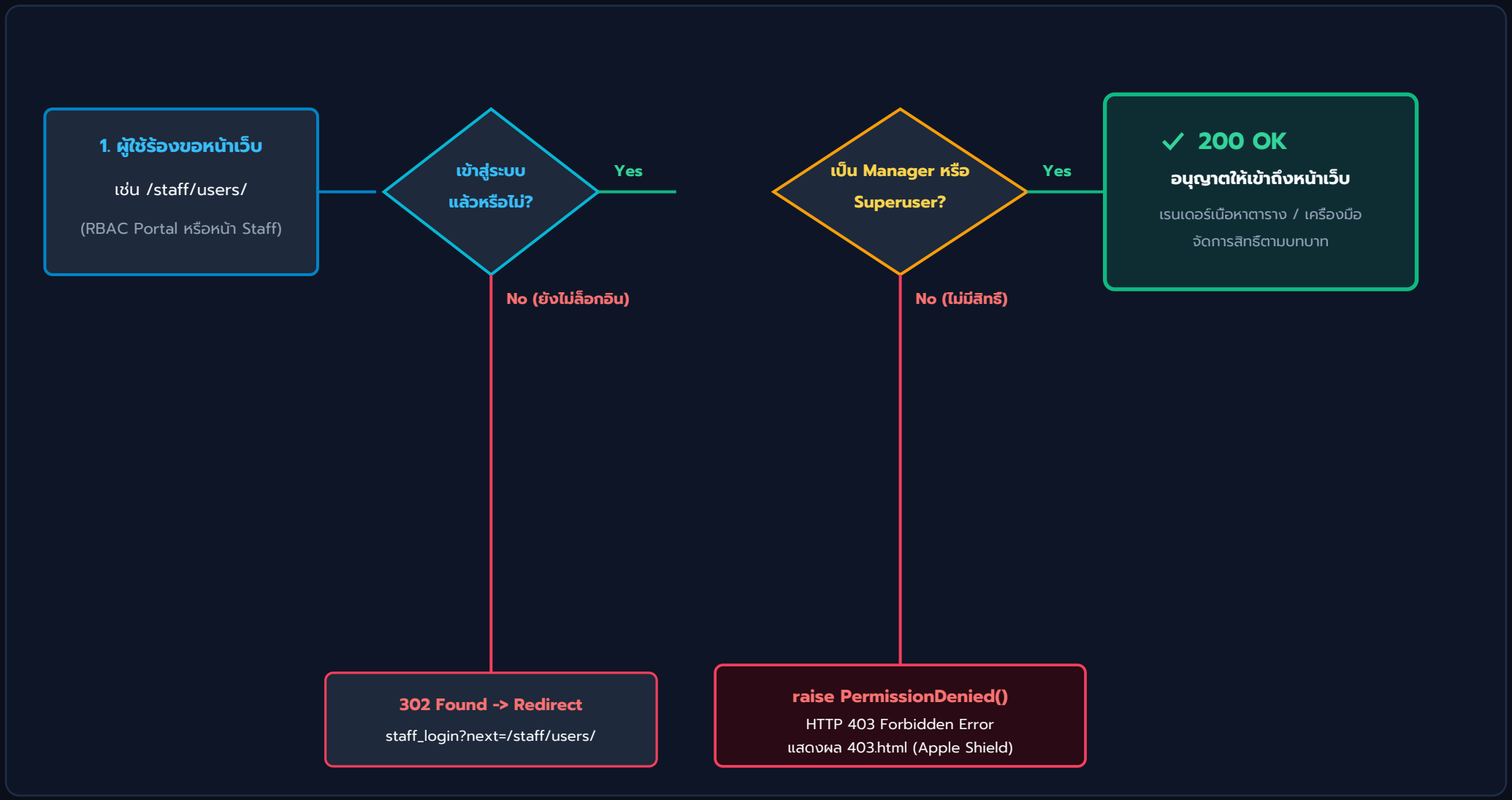


ส่วนที่ 4

แผนผังการทำงานของระบบ (System Flowcharts — Part 2)

3. การจำกัดสิทธิ์หน้าเว็บ & ข้อผิดพลาด 403 (Protected Pages & 403 Forbidden)

การตรวจสอบสิทธิ์ 2 ชั้น: ชั้นที่ 1 ยืนยันตัวตน (Authentication) -> ชั้นที่ 2 ตรวจสอบบทบาท (Authorization)



ส่วนที่ 5 สาธิตขั้นตอนวิธีการสร้างระบบ (Step-by-Step Code Tutorial)

ขั้นตอนที่ 1: ตรวจสอบความถูกต้องข้อมูลการสมัครสมาชิก (CustomerRegistrationForm)

PYTHON / myapp/forms.py

```python
class CustomerRegistrationForm(forms.Form):
    email     = forms.EmailField(label='อีเมล')
    phone     = forms.CharField(max_length=20)
    password1 = forms.CharField(min_length=6)
    password2 = forms.CharField(min_length=6)
    def clean_email(self):
        email = self.cleaned_data.get('email').lower()
        if User.objects.filter(username__iexact=email).exists():
            raise ValidationError('อีเมลนี้ถูกใช้งานแล้ว')
        return email
    def clean(self):
        if self.cleaned_data.get('password1') != self.cleaned_data.get('password2'):
            raise ValidationError('รหัสผ่านสองช่องไม่ตรงกัน')
```

ขั้นตอนที่ 2: ระบบเข้าสู่ระบบ & ควบคุมอายุเซสชัน (CustomerLoginView)

PYTHON / myapp/views.py

```python
class CustomerLoginView(View):
    def post(self, request):
        form = CustomerLoginForm(request.POST)
        if form.is_valid():
            email = form.cleaned_data['email']
            pwd   = form.cleaned_data['password']
            user  = authenticate(request, username=email, password=pwd)
            if user is not None:
                login(request, user)
                if form.cleaned_data.get('remember'):
                    request.session.set_expiry(1209600)  # 14 วัน
                else:
                    request.session.set_expiry(0)        # ปิดเบราว์เซอร์ล้าง
                return redirect('shop')
```

ขั้นตอนที่ 3: การจำกัดสิทธิ์หน้าเว็บเฉพาะผู้จัดการ (ManagerRequiredMixin)

PYTHON / myapp/views.py — ManagerRequiredMixin

```python
class ManagerRequiredMixin:  # ตรวจสอบสิทธิ์ระดับผู้จัดการร้าน
    def dispatch(self, request, *args, **kwargs):
        # 1. ตรวจสอบการยืนยันตัวตน
        if not request.user.is_authenticated:
            messages.warning(request, 'กรุณาเข้าสู่ระบบเจ้าหน้าที่ก่อน')
            return redirect(f'{reverse("staff_login")}?next={request.path}')

        # 2. ตรวจสอบบทบาท Manager หรือ Superuser
        is_manager = request.user.groups.filter(name='Manager').exists()
        if not (is_manager or request.user.is_superuser):
            raise PermissionDenied('คุณไม่มีสิทธิ์เข้าถึงหน้านี้')  # ส่ง HTTP 403 Forbidden -> 403.html

        return super().dispatch(request, *args, **kwargs)
```

ส่วนที่ 6

ตารางสรุปบทบาทและสิทธิ์การเข้าถึง (RBAC Role Matrix)

เมทริกซ์สรุปการเข้าถึงทุกเส้นทาง (URL Routes) และฟังก์ชันสำคัญในระบบตามบทบาทผู้ใช้งานทั้ง 4 กลุ่ม

หน้าเว็บ / ฟังก์ชันการทำงาน	Manager (ผู้จัดการ)	Staff (เจ้าหน้าที่)	Member (สมาชิก)	Guest (ผู้เยี่ยมชม)
/staff/users/ — RBAC Portal จัดการสิทธิ์	✓ อนุญาต	✗ ไม่อนุญาต	✗ ไม่อนุญาต	✗ ไม่อนุญาต
/employees/ — บริหารจัดการพนักงาน (CRUD)	✓ อนุญาต	✓ อนุญาต	✗ ไม่อนุญาต	✗ ไม่อนุญาต
/orders/ — ตรวจสอบและอัปเดตสถานะออเดอร์	✓ อนุญาต	✓ อนุญาต	✗ ไม่อนุญาต	✗ ไม่อนุญาต
/product/manage/ — จัดการสต็อกสินค้า	✓ อนุญาต	✓ อนุญาต	✗ ไม่อนุญาต	✗ ไม่อนุญาต
/dashboard/ & /reports/ — แดชบอร์ดและรายงาน	✓ อนุญาต	✓ อนุญาต	✗ ไม่อนุญาต	✗ ไม่อนุญาต
/account/ — โปรไฟล์, ที่อยู่ และประวัติการสั่งซื้อ	✓ อนุญาต	✓ อนุญาต	✓ อนุญาต	✗ ไม่อนุญาต
/shop/ & /cart/ — เลือกซื้อสินค้าและตะกร้า	✓ อนุญาต	✓ อนุญาต	✓ อนุญาต	✓ อนุญาต
/checkout/ — ชำระเงินและแจ้งสลิปโอนเงิน	✓ อนุญาต	✓ อนุญาต	✓ อนุญาต	✓ อนุญาต

คำนิยามบทบาทผู้ใช้งาน (Role Definitions & Django Groups):

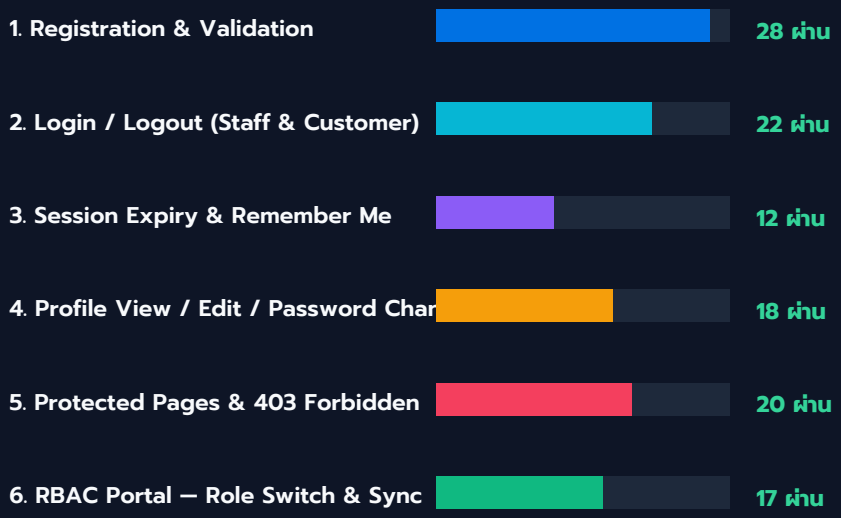
- **Manager (ผู้จัดการ)** — ผู้ดูแลระบบสูงสุด ครอบครองสิทธิ์ is_staff=True + อยู่ในกลุ่ม 'Manager' เข้าถึงได้ทุกหน้าในระบบ รวมถึง RBAC Portal
- **Staff (เจ้าหน้าที่)** — เจ้าหน้าที่ปฏิบัติงาน ครอบครองสิทธิ์ is_staff=True + อยู่ในกลุ่ม 'Staff' เข้าถึงหน้าจัดการพนักงาน, สินค้า, ออเดอร์ได้
- **Member (สมาชิกทั่วไป)** — ลูกค้าที่สมัครสมาชิก is_staff=False + อยู่ในกลุ่ม 'Member' สั่งซื้อสินค้า, มีหน้าโปรไฟล์ และประวัติออเดอร์
- **Guest (ผู้เยี่ยมชม)** — ผู้ใช้ทั่วไปที่ยังไม่ได้เข้าสู่ระบบ สามารถเลือกดูสินค้า เพิ่มสินค้าลงตะกร้า และสั่งซื้อสินค้าได้

นายธรรมธัช รูปไธสง · มรภ.กำแพงเพชร

ส่วนที่ 7

ชุดทดสอบระบบ & สรุปผลลัพธ์ (Test Results & System Summary)

✓ ชุดทดสอบอัตโนมัติ (Automated Test Suite — 117 Tests 100% Passed)



117 Tests — 100% PASSED

ผ่านครบถ้วนทุกกรณีทดสอบ (Edge Cases, Security & Roles)
ทดสอบบน Python 3.14 + Django 6.0.6

[+] จุดเด่นและคุณค่าของระบบ (System Highlights & Core Values)

Security First (ความปลอดภัยสูงสุด)

- รหัสผ่านเข้ารหัส PBKDF2 ด้วยเกลือ (Salt) สองทาง
- ออกจากระบบด้วย POST-only ป้องกันการโจมตี CSRF 100%
- ระบบบันไดสถานะออเดอร์ และจุดรับเงินจุดเดียว (Single Payment)

User Experience (ประสบการณ์ผู้ใช้ระดับ Apple)

- Apple Liquid Glass Design System หรูหราทันสมัย
- รองรับรูปโปรไฟล์และภาพพื้นหลัง GIF ขยับได้
- ระบบแสดงวันที่ปฏิทินไทย (พ.ศ.) และ Real-time Search

Code Quality & OOP (สถาปัตยกรรมโค้ดคุณภาพ)

- แยก Service Layer และ Class-Based Views (CBV) 100%
- Custom QuerySets / Managers สำหรับทุกโมเดล
- รองรับ REST API สำหรับโมบายล์แอปพลิเคชัน

ผู้พัฒนา: นายธรรมธัช รูปไธสง
สาขาวิทยาการคอมพิวเตอร์ มหาวิทยาลัยราชภัฏกำแพงเพชร
ระบบร้านค้าออนไลน์ THAMMATHAD SHOP · 2026